

DEVELOPER WORKSTATION SECURITY

Endpoint Hardening Checklist

Configuration required before an insider-threat investigation is possible

Phased implementation guide for IT administrators
Companion document: Endpoint Restrictions Reference

Purpose

This checklist covers the settings that must be applied to company-managed developer laptops **in advance of any incident**. It exists because post-incident forensic analysis can only examine evidence that was recorded and survived. Applying these settings after a suspected incident does not recover anything.

Two distinct reasons drive the controls below:

1. **Some settings close an exfiltration channel.** A blocked channel cannot be used.
2. **Some settings do not restrict the employee at all.** They exist so that the evidence needed to investigate is generated in the first place, and cannot be quietly erased afterwards.

The second group is easy to overlook and is the cheaper of the two. Several of the most valuable evidence sources on Windows 10 and 11 are **switched off by default** and record nothing at all unless an administrator enables them. Others exist by default but can be deleted by a standard user with no administrator rights whatsoever.

The failure this prevents

Forensic triage does not report an error when evidence was never created. It completes normally, finds nothing, and produces a clean report. On an unconfigured laptop, that clean report is indistinguishable from a genuine finding of no wrongdoing.

Configuring the endpoint in advance is what makes an empty result meaningful.

How to use this document

Work through the phases in order. Phase 1 requires no restriction on any employee and can be applied immediately; it resolves every "records nothing at all" gap on its own.

Each phase ends with a **sign-off block** left deliberately blank. Print the checklist and complete it by hand: the person who applied the phase, and a second person who independently verified it on a real endpoint. Verification by someone other than the implementer is what catches a policy that was configured but never reached the target machine group.

Each control has an identifier such as `EP-04`. Full settings — Group Policy paths, registry values, verification commands, and developer-impact notes — are in the companion document `organizational-prerequisites.md`, indexed by the same identifiers.

Priority	Meaning
P0	Without it, post-incident investigation is not possible at all
P1	Without it, a specific category of evidence is unavailable
P2	Closes an additional exfiltration channel

Phase 1 — Silent Configuration

Timeline: weeks 1-2. No user-visible change. No exception requests. Apply regardless of any decision on later phases.

Nothing in this phase restricts an employee's ability to do anything. Every item either enables a log that is currently off, enlarges one that is currently too small, or preserves data that is currently discarded.

☐	ID	Control	Priority	Why it matters
☐	EG-01	Enable the device connection/removal event channel	P0	Off by default. It is the only reliable source of USB insertion and removal times. Without it there are no device sessions to correlate file activity against — the investigation cannot start.
☐	EG-02	Enable object access auditing and apply audit rules to protected project directories, the user's recent-items folder, and per-user volume mount keys	P1	Off by default. Produces the file access records that link activity to a device session. Auditing the evidence locations themselves also means deletion of evidence becomes a logged event.
☐	EG-03	Enable removable storage auditing	P1	Records access specifically to removable media. Fires only when removable media is used, which is rare on a developer machine.
☐	EG-04	Enable command-line capture in process creation auditing	P1	Without it, logs show that a copy utility ran but not what it copied.
☐	EG-05	Enable PowerShell script block and module logging	P1	Captures the actual script content, including scripts that were obfuscated before execution.
☐	EP-03	Raise maximum event log sizes	P1	Default sizes overwrite within days on a busy developer machine. Older sessions are silently lost.
☐	EP-04	Ensure volume shadow copies are enabled, sized, and retained	P1	Highest-value single item in this phase. The only mechanism that recovers evidence a standard user deleted from their own profile. Also gives developers free local rollback.
☐	EP-05	Enforce recent-items and jump list tracking, and lock the setting	P1	A standard user can switch this off in one registry value, with no elevation. Both file-history evidence sources then stop being created — permanently and silently.
☐	OB-01	Make forensic imaging of returned laptops a mandatory offboarding step	P0	If the disk is wiped for the next employee before anyone investigates, every other control on this list is worthless.

Phase 1 sign-off complete by hand after applying

Applied by	Date	Verified by	Date

Phase 2 — Foundational Controls

Timeline: weeks 3-6. Expect elevation requests in the first fortnight. Staff the request process before starting.

☐	ID	Control	Priority	Why it matters
☐	PB-01	Remove standing local administrator rights; provide time-boxed elevation with logged justification	P0	Most evidence-destroying actions require administrator rights. This single change removes the majority of them.
☐	PB-02	Enforce full-disk encryption with pre-boot authentication and escrow recovery keys centrally	P0	Without it, the disk can be removed and read on another machine, leaving no trace on the laptop.
☐	PB-03	Set a firmware supervisor password, enable Secure Boot, and disable boot from USB and network	P0	Booting a different operating system from a USB stick bypasses Windows entirely and generates no evidence of any kind . This is the single scenario that defeats every other control listed here.
☐	EP-01	Revoke standard users' right to clear security logs	P0	One command otherwise erases the entire local audit history.
☐	EP-02	Forward event logs to a central log platform in real time	P0	Once a record has left the laptop, clearing the local log destroys nothing. This is the strongest single defence against log wiping.
☐	EG-06	Enable tamper protection on endpoint security agents	P0	Prevents the security tooling itself from being disabled.
☐	EP-07	Remove the legacy PowerShell v2 engine from the standard image	P1	It bypasses script block logging entirely, defeating EG-05.
☐	PB-04	Deny standard users the right to change the system clock; enforce network time sync	P2	All correlation is time-based. A manipulated clock corrupts the entire timeline.

PB-02 and PB-03 are one control in two halves. Encryption without a locked boot order still permits a live-USB boot that generates no Windows evidence. A locked boot order without encryption is defeated by removing the drive. Neither is sufficient alone.

Phase 2 sign-off complete by hand after applying

Applied by	Date	Verified by	Date

Phase 3 — Channel Restrictions

Timeline: weeks 7-10. Publish the approved-peripheral catalogue before enforcing.

☐	ID	Control	Priority	Why it matters
☐	RM-01	Restrict removable storage across all device classes, not USB alone	P1	Covers memory cards, optical media, and phone/media-device connections. Restricting USB alone leaves the others open.
☐	RM-03	Require removable drives to be encrypted before they can be written to, with recovery keys escrowed centrally	P1	Definitive proof that a specific file reached a specific device requires the recovered device to be readable . Without this, an employee who encrypts their own drive puts that proof permanently out of reach.
☐	RM-04	Disable Bluetooth file transfer, Wi-Fi Direct, and mobile tethering profiles	P2	A Bluetooth transfer produces no USB storage evidence of any kind . Peripherals such as mice, keyboards, and headsets continue to pair normally.
☐	RM-05	Enable print job auditing	P2	Printing source code is otherwise entirely unrecorded. Printing behaviour is unchanged; only the audit record is added.
☐	RM-02	Restrict device installation to an approved hardware catalogue	P2	Requires a request process for new peripherals. Consider only if the risk assessment justifies the overhead.

Phase 3 sign-off complete by hand after applying

Applied by	Date	Verified by	Date

Phase 4 — Application Control

Timeline: week 11 onward. Run in audit mode for four to six weeks first.

☐	ID	Control	Priority	Why it matters
☐	EP-06	Deploy application allowlisting; block execution from temporary folders, downloads, and removable media	P1	Blocks the purpose-built utilities that exist specifically to erase USB connection history and file access records.
☐	EG-07	Deploy extended process, file, and network telemetry with a tuned exclusion list	P2	Substantially widens evidence coverage. Requires tuning to avoid enormous log volume during compilation.

This is the highest-friction phase on the list. Deploying without an audit period will generate legitimate complaints and is the item most likely to be rolled back. Build the approved-software list from real observed usage rather than from a predicted list, and keep a fast exception path open.

Phase 4 sign-off complete by hand after applying

Applied by	Date	Verified by	Date

Ongoing Process Controls

Not a phase — these are permanent procedural requirements.

☐	ID	Control	Priority
☐	OB-02	Extend log retention and raise alerting sensitivity for employees serving notice, disclosed in advance in policy	P1
☐	OB-03	Document chain of custody for every device image: who, when, which tool, and the cryptographic hash of the image	P0
☐	OB-04	Publish an acceptable use policy disclosing endpoint logging; define who may authorise an investigation; restrict report access to need-to-know; obtain legal review	P0

Verification

After each phase, run the verification script in `organizational-prerequisites.md`, Part 6, on a representative machine. It is read-only and changes nothing.

The most common failure is a policy that was configured but never applied to the target machine group. Verify on an actual developer laptop, not on the management console.

A Note on Developer Impact

Developer machines are a special case. Engineers need broad system privileges, fast filesystem access, and unrestricted command-line use. Controls that block terminal access or scan every file write in real time break compilation and will be circumvented or reversed.

This checklist is deliberately built to avoid that outcome:

- **Phase 1 restricts nothing.** It only changes what is recorded and retained.
- **Phase 2 restricts elevation, not capability.** Development toolchains, containers, and local builds do not require administrator rights.
- **Phase 3 targets channels engineers do not use** for legitimate work, since code and dependencies move through version control and internal package repositories.
- **Phase 4 is the only phase with real friction**, and is scheduled last and behind an audit period for that reason.

Each control in the reference document carries an honest impact assessment. A control that is quietly reversed after complaints provides no protection, so it is better to defer one than to deploy it without preparation.

Governance

These controls process data about employee activity. Before deployment, ensure there is an acceptable use policy disclosing that endpoint activity is logged and that company devices may be forensically examined, a defined incident response process naming who may authorise an examination, role-based access to any resulting report, and legal review of the whole arrangement.

Forensic triage of this kind is intended for authorised examiners working on company-owned equipment within a defined process. It is not a mandate for covert or continuous surveillance of staff.